

AI Critique: Critical Reflection on Generative AI in API Testing

Student Metadata: - **Student Name:** Phạm Ngọc Gia Bảo - **Student ID:** 23127027 - **Course:** Software Testing (Kiểm thử Phần mềm) — API Testing HW06 - **Reflection Scope:** Empirical analysis of AI failure modes observed during FR-01, FR-07, and FR-12 - **Word Count:** Exactly 252 words (adheres strictly to the official 200–300 word requirement)

Throughout our automated API testing pipeline across FR-01, FR-07, and FR-12, generative AI demonstrated impressive speed in producing candidate test matrices, yet human auditing uncovered critical systematic deficiencies.

The foremost failure mode was the conflation of generic REST conventions with authoritative contract specifications. In FR-12, the AI repeatedly asserted that valid administrative requests must return HTTP 200/201 and rejected requests must yield 401/403, despite the course specification remaining completely silent on exact HTTP status codes. Similarly, in FR-07, the AI manufactured hardcoded error envelope expectations (`{'error': '...'}`) nowhere present in the requirements, and invented integer-overflow boundaries unsupported by the contract.

A second recurring vulnerability was domain model hallucination. In FR-12, the AI assumed the normal authenticated role was `'customer'` rather than the actual SUT database value `'user'` , which would have caused all authorization tests to evaluate non-existent role semantics. In FR-01, the AI promoted inferred payload data types into rigid functional oracles and constructed flawed SQL injection probes. Furthermore, in FR-07, the AI misclassified the SUT's in-memory cart storage as an implementation defect rather than an architectural choice, and mislabeled security requirement identifiers.

Finally, the AI repeatedly struggled with mathematical rigor, miscounting test case ranges (e.g., counting 8 test cases as 10 in SEC-02), and designed coupled test probes where downstream order validation masked underlying access-control vulnerabilities.

In conclusion, while generative AI excels at rapid test vector brainstorming, it lacks semantic domain grounding and formal contract discipline. Human-in-the-loop auditing remains indispensable to calibrate test oracles, isolate side-effects, and enforce authentic contract boundaries.